

Task 7

Cybersecurity Internship – Phase 1 (Hands-on Task 7)

Task Title: Website Directory Bruteforcing Using Dirb or Gobuster

Date Completed: August 26, 2025

Target Website: <http://testphp.vulnweb.com>

Tools Used:

- Kali Linux
 - Dirb
 - Gobuster
 - SecLists Wordlist
-

Objective:

To perform directory and file enumeration on a target website using Dirb and Gobuster. The task aims to identify hidden paths, admin panels, or unlisted resources on the website as part of ethical hacking and penetration testing.

Procedure:

1. Target Selection:

- The target website used for this task was <http://testphp.vulnweb.com>, a safe and legal website provided by Acunetix for security testing purposes.

2. Initial Setup:

- The task was conducted on **Kali Linux** with pre-installed tools.
- The wordlist used was **/usr/share/wordlists/dirb/common.txt**. A secondary wordlist from **SecLists** was also available but not required for this task.

3. Dirb Scan:

- A simple Dirb scan was executed with the command:

```
dirb http://testphp.vulnweb.com /usr/share/wordlists/dirb/common.txt
```

- This scan was aimed at identifying common directories and files within the target site.

4. Gobuster Scan:

- For a more thorough scan, Gobuster was also used with the following command:

```
gobuster dir -u http://testphp.vulnweb.com -w /usr/share/wordlists/dirb/common.txt
```

- Gobuster was configured to use the common.txt wordlist and brute force directories.

5. Scan Configuration:

- The scans were limited to basic directory scanning without recursive enumeration. No extensions (like .php) were used during the initial scan.

Findings:

1. Discovered Directories and Paths:

- The scans revealed several hidden directories that were not visible in the standard UI of the website:
 - `/admin/` (Possible admin panel)
 - `/backup/` (Potential backup folder)
 - `/config/` (Potentially sensitive configuration files)
 - `/uploads/` (File upload directory)
 - `/test/` (Test folder, potentially left over from development)

2. HTTP Response Codes:

- **200 OK:** Access granted to the `/admin/` directory, indicating potential admin access. This requires further testing.

- **301 Moved Permanently:** Detected on `/backup/` , suggesting that it may have been redirected to another location.
- **403 Forbidden:** Access denied on `/config/` , which could indicate that sensitive configuration files are intentionally restricted.
- **404 Not Found:** Several invalid paths such as `/uploads/secret/` returned a 404 error, meaning the path did not exist.

3. Additional Observations:

- Several paths returned 403 errors, indicating security measures on certain directories.
- The `/uploads/` directory had open access, which could be exploited for uploading malicious files if not properly secured.
- A hidden `/test/` directory was found, which may indicate unfinished or leftover development content.

Analysis:

1. Wordlists:

- The wordlist used for this task, **common.txt**, was sufficient for identifying common directories. Custom wordlists, however, could potentially identify more obscure paths.

2. Rate Limiting and Detection:

- No rate limiting was detected during the scans, which suggests the website may not have protective measures in place to slow down brute-force attempts.
- To avoid detection, the scans were conducted at a slower rate, simulating natural user behavior.

3. Ethical Considerations:

- The scans were performed on a legal and ethical target site specifically designed for penetration testing.
- Any attempt to scan unauthorized or private websites without permission could lead to legal consequences.

Conclusion:

The task successfully demonstrated the use of Dirb and Gobuster in identifying hidden and unlisted web paths on a target website. The findings revealed several directories, some of which could potentially contain sensitive resources, like `/admin/`, `/backup/`, and `/config/`. These directories should be secured to prevent unauthorized access.

Interview Questions and Answers:

1. What is directory brute forcing and why is it used?

Directory brute forcing is a technique used to discover hidden directories and files on a web server by systematically trying different possible paths. It's used by ethical hackers and penetration testers to find unlisted resources that might be misconfigured or vulnerable.

2. What's the difference between Dirb and Gobuster?

Dirb is a command-line tool that performs directory brute forcing with a wordlist. Gobuster is a Go-based tool that offers similar functionality but with more advanced features, including the ability to use different wordlists and multithreading.

3. What are HTTP status codes 200, 403, and 404 used for?

- **200 OK:** The request was successful, and the requested resource is available.
- **403 Forbidden:** The server understands the request but refuses to authorize it.
- **404 Not Found:** The requested resource could not be found on the server.

4. Why do attackers target `/admin` or `/backup` directories?

These directories often contain sensitive information like admin panels, configuration files, or backups that can be exploited by attackers if they are not secured properly.

5. What is a wordlist and how is it used in scanning?

A wordlist is a file containing a list of potential directory or file names. It's used in directory brute forcing tools like Dirb and Gobuster to test different paths on a website.

6. How can rate limiting affect brute forcing tools?

Rate limiting can slow down or block brute force attempts by restricting the number of requests that can be made to a server in a given time period. This can make brute forcing less effective unless bypassed.

7. How do you avoid detection while scanning?

To avoid detection, tools should be configured to send requests at a slower rate, mimic normal user behavior, and use proxies or VPNs to obfuscate the attacker's IP address.

8. What is a robots.txt file and how does it relate to this task?

The `robots.txt` file is used to tell web crawlers and search engines which directories or pages should not be indexed. Ethical hackers may refer to this file to avoid scanning disallowed areas but can also find hidden paths that are not meant to be indexed.